

- ❖ Las respuestas que no se ajusten estrictamente al enunciado, no serán aceptadas.
- ❖ Condición para aprobar: Al menos un ejercicio bien resuelto.

Ejercicio 1

El edificio Helios usa pulseras electrónicas para controlar el acceso a las puertas.

Cada pulsera tiene un identificador público ID, una clave simétrica K de 128 bits, y un bit `wearing` que indica si está siendo usada por una persona (1) o no (0).

Cada 2 segundos, la pulsera transmite vía bluetooth (utilizando BLE broadcast, sin emparejamiento previo:)

Pulsera $\rightarrow$ aire: (ID, ctr, C), donde ctr es un contador que empieza en 0 y se incrementa, y $c = \text{AES-CTR}_k(\text{wearing} \parallel \text{ctr})$ y k es una clave de 128 bits específica para cada pulsera.

Los controladores de cada puerta escuchan BLE y reenvían cada mensaje a un servidor central por un canal considerado seguro:

Controlador $\rightarrow$ Servidor: (door_id, timestamp, ID, ctr, C)

El servidor conoce K para cada ID y descifra de cada mensaje el valor C. Si de dicho descifrado, ctr coincide con el valor enviado en plano, y el empleado figura en la base de datos como autorizado para abrir esa puerta, avisa al controlador que libere la cerradura. Sino, registra el incidente y no permita que se abra la puerta.

En caso de caída de red (donde los controladores no podrían comunicarse con el servidor), algunas puertas pasan a modo "degradado": si detectan cualquier mensaje con un ID autorizado recientemente, abren la puerta sin consultar al servidor.

- Describir qué verificaciones adicionales podría realizar el servidor para detectar usos con los siguientes patrones extraños: intento de abrir dos puertas lejanas casi al mismo tiempo, intento de abrir puertas fuera del horario normal. (1 pto.)
- Un atacante puede escuchar y transmitir mensajes BLE a su entera discreción. Explicar cómo podría modificar o reutilizar mensajes escuchados para conseguir abrir una puerta. Proponer una solución. (1 pto.)
- Si un atacante logra forzar el modo degradado, es trivial repetir un mensaje reciente y conseguir que se abra la puerta. Proponer alguna mejora que mitigue el problema sin introducir nuevos dispositivos o enlaces al sistema. (1 pto.)

Ejercicio 2

Un sistema de control de acceso utiliza el siguiente protocolo de autenticación entre un cliente C y un servidor S. Cada cliente comparte con el servidor una clave secreta K_C . $H(\cdot)$ es una función de hash libre de colisiones:

1. $C \rightarrow S: id$
2. $S \rightarrow C: r$ (un número aleatorio de 128 bits)
3. $C \rightarrow S: t = H(K_c \parallel r)$
4. S busca la clave K_c asociada a id , recalcula $H(K_c \parallel r)$ y acepta la autenticación si coincide con t .

a) Explicar por qué este protocolo es mejor que un cliente enviado solo un hash de la clave secreta (1 pto.)

b) Para evitar la aleatoriedad en el protocolo, un desarrollador decide modificar el paso 2 y mantener un contador ctr , que transmite en lugar de r y va incrementando en cada uso. ¿Es esta implementación menos segura que la anterior? justificar (1 pto.)

c) Modificar el protocolo para que exista autenticación mutua, es decir, que C también pueda autenticar a S como resultado del intercambio. No introducir nuevas claves. (1 pto.)

Ejercicio 3

La empresa CasaIA vende dispositivos inteligentes para hogares (cerraduras inteligentes, luces, cámaras) que se controlan desde una aplicación móvil y desde una página web.

Cada usuario crea una cuenta con email y contraseña. La autenticación se hace contra un API REST centralizado, que devuelve un token de sesión.

Para vincular un dispositivo, el usuario escanea con la app un código QR impreso en el equipo; este código contiene el identificador del dispositivo y una clave de emparejamiento.

Los dispositivos se conectan por WiFi a los servidores de CasaIA utilizando un protocolo propietario sobre TCP, con un canal persistente para recibir comandos (abrir/cerrar, encender/apagar, etc.).

El sistema permite definir escenarios (por ejemplo, "modo vacaciones", "modo noche"). Los escenarios se configuran desde la app/web, y el servidor los ejecuta enviando comandos a los distintos dispositivos según la hora, la geolocalización del teléfono del usuario, o sensores (movimiento, luz).

El sistema permite otorgar acceso temporal a invitados: el dueño de la casa ingresa el email de la otra persona, y el sistema le envía un enlace que, al abrirlo, permite controlar ciertos dispositivos durante una ventana de tiempo configurable.

En función de la descripción del sistema, establecer 4 hipótesis de falla plausibles siguiendo la metodología de pentesting. Por cada hipótesis definir una prueba siguiendo los lineamientos de la metodología. (1 pto c/u).

Aclaración: No utilizar problemas genéricos como hipótesis de falla. Plantear situaciones y lugares concretos donde podría estar el problema. Por ejemplo, en lugar de decir "puede haber un buffer overflow", decir "es probable que haya un buffer overflow en la lectura del parámetro x que debe interpretarse como número y puede tener un buffer pequeño dado que los números esperados tienen menos de 4 dígitos".